NOTE

The examples in this section use an API gateway, but any of the three architectural patterns forprotecting APIs discussed earlier in this chapter would work as well.

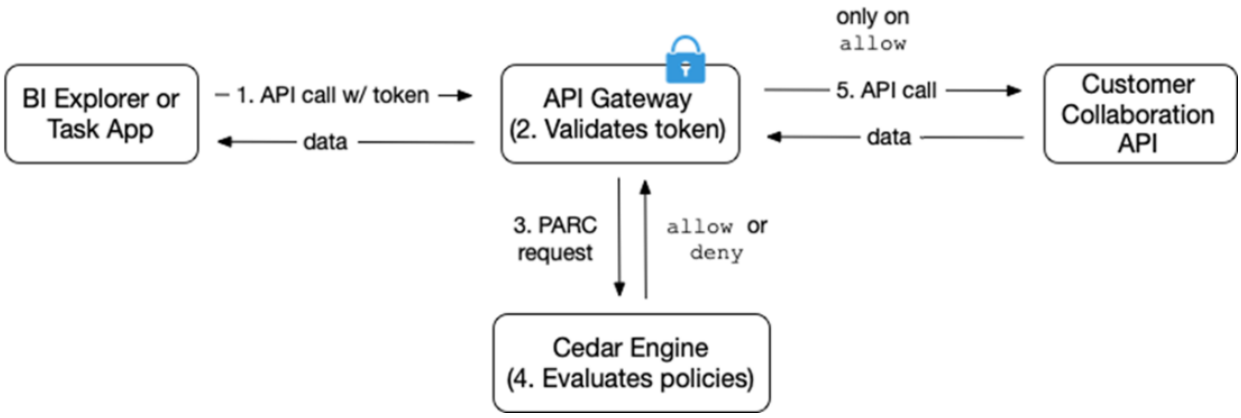


Figure 11.8 Using an OAuth token with Cedar. The client (BI Explorer or Task App) includes an access token in its API request. The API gateway validates the token and then creates a PARC request for Cedar. Only if Cedar grants permission does the request proceed to the Customer Collaboration API and return data.

These are the steps shown in figure 11.8:

1. **Client presents token.** Each request to ACME's APIs must include the token in the HTTP header:

```
Authorization: Bearer <access_token>
```

2. **Gateway validates token.** The API gateway (acting as the policy enforcement point) checks the token before doing anything else by verifying the signature, issuer, and expiration. It also confirms that the token includes the necessary scopes for the API being called. Additionally, the gateway identifies the caller: Kate (for the BI Explorer) or the integration principal (for the Task App).
3. **Gateway constructs a PARC request.** Next, the gateway converts the API call into a Cedar request:
    - Principal: taken from the token (user or integration)